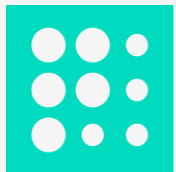


PeoplePath

Implementace SELinuxu

**Aneb když si
zabezpečíte systém i
sami před sebou**





PeoplePath

- Jsme globálním **poskytovatelem softwaru** v oblasti hledání a správy talentů – pomáháme zaměstnavatelům identifikovat, zaujmout a získat nejlepší talenty.
- V Plzni vyvíjíme náš jediný produkt – robustní **webovou aplikaci**.

60+
zaměstnanců

100+
klientů

4 000 000+
profilů talentů

Seattle
USA

San Diego
USA

Nashville
USA

New York
USA

London
UK

Mnichov
GER

Plzeň
CZE



PeoplePath

Implementace SELinuxu

**Aneb když si
zabezpečíte systém i
sami před sebou**



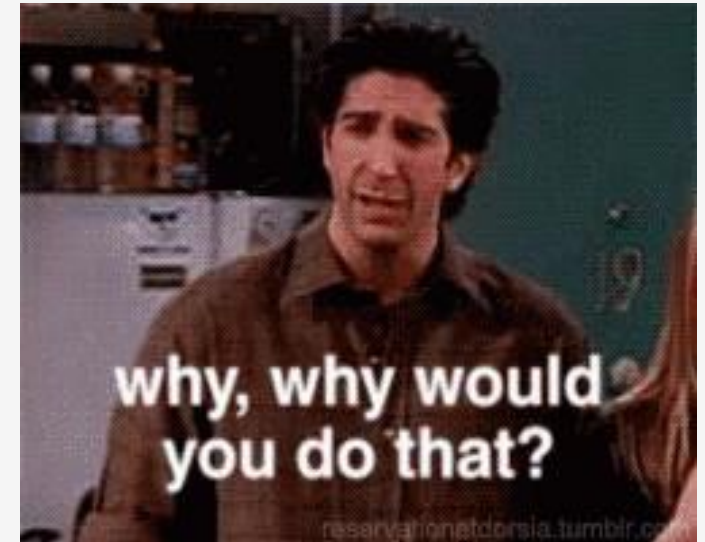
O Mně

- Jan Žemlička
- System configuration manager
- jan.zemlicka@peoplepath.com



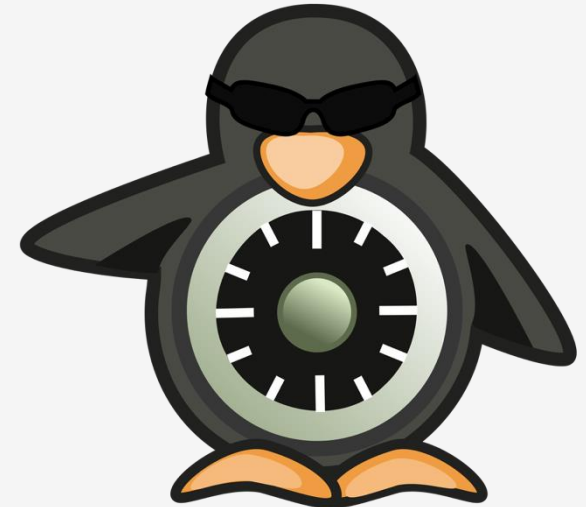
Program – O čem to dneska bude?

- **úvod – trocha teorie o tom co SELinux je**
- **bezpečnostní modely, a proč ho chceme**
- **jak SELinux funguje, základní pojmy**
- **jednoduchá ukázka běžícího SELinuxu a Apache**
- **analýza AVC logu**
- **ukázka reálné implementace**
- **správa nainstalovaných SELinux policy modulů**
- **integrace SELinuxu do orchestrátoru (puppet)**
- **monitoring SELinuxu a udržitelnost**



Co vůbec SELinux je?

- zkratka SELinux = Security-Enhanced Linux
- bezpečnostní vrstva v jádře Linuxu
- předinstalovaný ve všech Linuxových distribucích rodiny RedHat
- vyvinut americkou NSA v roce 2000, opensource od 2003
- alternativy, AppArmor



Model	Kdo rozhoduje	Princip	SELinux
DAC Discretionary	Vlastník objektu	Vlastník nastavuje chmod, chown; oprávnění lze delegovat	vrstva pod MAC
MAC Mandatory	Systémová politika	Centrální pravidla, nelze obejít ani rootem	targeted
RBAC Role-Based	Role uživatele	Oprávnění plynou z přiřazené role, ne z identity	Role v kontextu
MLS Multi-Level Security	Klasifikační úrovně	No read up, no write down; chrání tajnost	MLS (volitelné)

Základní pojmy

- **targeted režim využívá labely – kontextové typy a kontextové domény**
- **labely přiřazené k procesům -> kontextová doména**
- **labely přiřazené objektům -> kontextový typ**

Kontextové domény

- SELinux labely přiřazené ke všem procesům v systému
- výpis procesů i s labely -> ps auxZ

```
unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023 root 2765362 0.0 0.0 226712 3488 pts/2 R+ 13:34 0:00 ps auxZ
system_u:system_r:spc_t:s0 apache 2856276 0.0 0.9 639112 73104 ? S Apr02 0:02 php-fpm: pool web
system_u:system_r:spc_t:s0 apache 3436557 0.0 1.1 639196 92992 ? S Apr02 0:00 php-fpm: pool web
system_u:system_r:syslogd_t:s0 root 3665296 0.0 0.1 1232068 11852 ? Sl Apr05 0:08 /bin/rsyslog_export
timed out waiting for input: auto-logout
awseu jan.zemlicka@seweb01:~$
```

Kontextové typy

- SELinux labely přiřazené ke všem objektům
- druhy objektů: soubory, složky, porty, sock files atd.
- výpis souborů i s labely -> ll -Z

```
awseu root@aint02:/home/jan.zemlicka# ll -Z /var/www/
total 4.0K
drwxr-xr-x.  4 root root system_u:object_r:httpd_sys_content_t:s0      33 Dec 12 18:17 .
drwxr-xr-x. 23 root root system_u:object_r:var_t:s0                    4.0K Mar 19 14:13 ..
drwxr-xr-x.  2 root root system_u:object_r:httpd_sys_script_exec_t:s0    6 Dec 12 18:17 cgi-bin
drwxr-xr-x.  2 root root system_u:object_r:httpd_sys_content_t:s0      6 Dec 12 18:17 html
```

SELinux policy

- soubor pravidel – říká která kontextová doména může přistupovat ke kterému kontextovému typu
- všechno, co není v policy, je zamítnuto
- instalovány společně s aplikací



Režimy SELinuxu

- disabled
- permissive
- enforcing (default)
- persistované nastavení: `/etc/selinux/config`
 - SELINUX=disabled
 - SELINUX=permissive
 - SELINUX=enforcing
 - změna vyžaduje reboot
- live přepnutí režimu: `setenforce 0/1`
 - 0 – permissive
 - 1 – enforcing



Ukázka (ne)běžícího Apache

- **Apache HTTP server ve virtualizovaném Rocky Linuxu**
- **SELinux defaultně v enforcingu**
- **povolení/zakánání zobrazení index.html pomocí SELinuxu**
- **změna selinux labelu souboru**



Špatně nakonfigurovaný Apache

- Apache má povolenou funkci mod_cgi, spouštění scriptů
- konfigurace která povoluje exekuci čehokoliv
- server zneužitelný k RCE
- <http://localhost/cgi-bin/search.sh?cmd=ls+-al+/home>



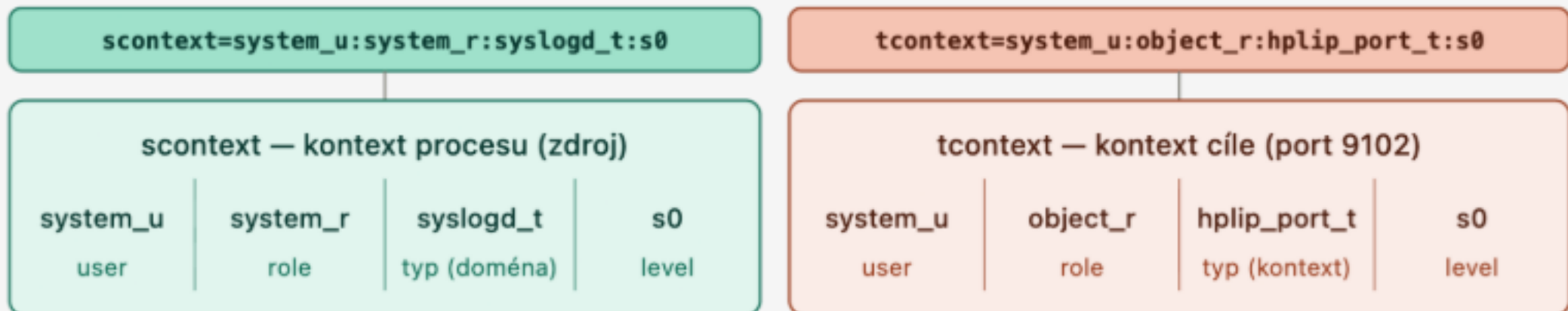
Analýza logů SELinuxu

- **AVC – Access Vector Cache - modul v kernelu, který loguje přístupy**
- **defaultně zpracovává audit daemon**
- **`cat /var/log/audit/audit.log | grep avc`**

```
type=AVC msg=audit(1771230288.262:642): avc: denied { name_bind } for pid=9954  
comm="rsyslog_exporte" src=9102 scontext=system_u:system_r:syslogd_t:s0  
tcontext=system_u:object_r:hplip_port_t:s0 tclass=tcp_socket permissive=0
```



— Bezpečnostní kontexty (user : role : type : level) —



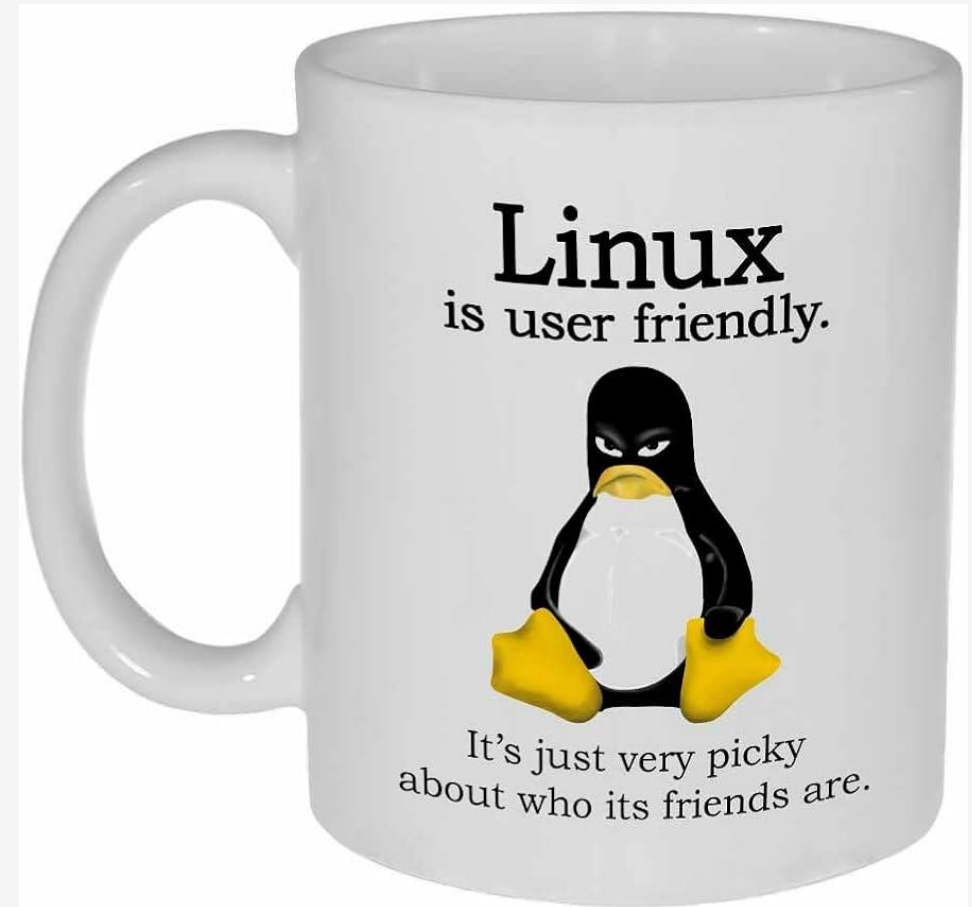
Zkusíte si sami zanalyzovat AVC zprávu?

**type=AVC msg=audit(1775791468.735:291247): avc: denied { read } for pid=3066010
comm="docker-compose" name=".env-ai" dev="nvme0n1p2" ino=25579939
scontext=system_u:system_r:nrpe_t:s0 tcontext=unconfined_u:object_r:user_home_t:s0
tclass=file permissive=0**



Trochu více human-friendly logy

- **sealert – detailní analýza logů**
- **doporučuje řešení daného „denialu“**
- **součást balíku setroubleshoot-server**
- **sealert –a selinux_zpravy.log**
- **detekce zpráv, které už byli vyřešené**



Jak se tedy „denied“ přístupů zbavit?

- změna kontextu nad objektem
- SELinux boolean
- vytvoření vlastní SELinux policy
- většinou kombinace první a třetí možnosti

Řešení reálných AVC

Změna file kontextu, vlastní SELinux policy

- **semanage fcontext – správa file kontextů**
- **restorecon - relabel kontextu přímo na souborech**
- **audit2allow - vytvoření vlastní SELinux policy**
- **a proč ne cat /var/log/audit/audit.log | audit2allow –M vsechno ????**
- **cat temp.log | audit2allow –M password_expiration_check**
- **semodule –i password_expiration_check.pp**

.te - Type enforcement

“SELinux programovací jazyk”

- **module** – název, verze
- **require** – “definice proměnných”
- **allow** – samotná pravidla

```
module password_expiration_nrpe_pph 1.0;
```

```
require {  
    type shadow_t;  
    type nrpe_t;  
    type sshd_t;  
    type passwd_t;  
    type init_t;  
    class capability dac_read_search;  
    class file { getattr open read };  
    class dir search;  
    type nagios_tmp_t;  
}
```

```
#===== nrpe_t =====  
allow nrpe_t self:capability dac_read_search;  
allow nrpe_t shadow_t:file { getattr open read };  
allow nrpe_t nagios_tmp_t:dir search;
```

```
#===== passwd_t =====  
allow passwd_t sshd_t:dir search;  
allow passwd_t init_t:dir search;  
allow passwd_t sshd_t:file { getattr open read };
```

Zkompilování a instalace .te

- **checkmodule -M -m -o <module_name>.mod <module_name>.te**
- **semodule_package -o <module_name>.pp -m <module_name>.mod**
- **semodule -i <module_name>.pp**

Řešení reálných AVC

Přepnutí booleanu

- **předinstalovaný přepínač operací**
- **setsebool <jmeno-booleanu>=1/0**
- **getsebool <jmeno-booleanu>**
- **getsebool -a**

Me: I'm afraid of booleans. My friend said that you can help.

Therapist: That's true.

Me:



Zbytečně „moc otevřený“ boolean?

```
#===== nrpe_t =====  
  
#!!!! This avc can be allowed using the boolean 'domain_can_mmap_files'  
allow nrpe_t container_runtime_exec_t:file map;  
allow nrpe_t container_runtime_exec_t:file { execute execute_no_trans getattr open read };  
  
#!!!! This avc can be allowed using the boolean 'daemons_enable_cluster_mode'  
allow nrpe_t container_runtime_t:unix_stream_socket connectto;  
allow nrpe_t container_var_run_t:sock_file write;  
allow nrpe_t container_unit_file_t:service status;  
  
#!!!! This avc can be allowed using the boolean 'daemons_enable_cluster_mode'  
allow nrpe_t self:unix_stream_socket connectto;  
allow nrpe_t sysctl_net_t:dir search;  
allow nrpe_t sysctl_net_t:file { open read };  
allow nrpe_t systemd_systemctl_exec_t:file execute;
```


Správa nainstalovaných modulů

jmenná konvence

- **semodule -l**
- **tvorba systému jmen vlastních modulů**
- **<jmeno-sluzby> <pripadne-nrpe> <_pph>**
- **password_expiration_nrpe_pph**
- **semodule -l | grep pph**
- **semodule -l | grep nrpe_pph**



Správa nainstalovaných modulů

Základní funkce semodule

- **vylistování všech modulů - semodule -l**
- **instalace - semodule -i <policy_package>.pp**
- **odinstalace - semodule -r <jmeno_modulu>**
- **deaktivace - semodule -d <jmeno_modulu>**
- **zpětná aktivace - semodule -e <jmeno_modulu>**

SELinux a orchestrační nástroje (Puppet)

Jak SELinux udržovat a nezbláznit se z toho?

- **naše struktura konfigurace v Puppetu**
- **přidávání konfigurace SELinuxu per-slужba**
- **je potřeba nainstalovat SELinux puppet module**
- **puppet module install puppet-selinux**

SELinux a orchestrační nástroje (Puppet)

Základní konfigurace

nastavení režimu

```
class { 'selinux':  
  
    mode => 'enforcing',  
  
    type => 'targeted',  
  
}
```

instalace modulu

```
selinux::module { "core_pph":  
  
    ensure    => 'present',  
  
    source_te => 'puppet:///modules/core/selinux/core.te',  
  
    builder   => 'simple',  
  
}
```

```
modules > core > files > selinux > core.te  
1  module core_pph 1.0;  
2  
3  require {  
4      type initrc_t;  
5      type NetworkManager_t;
```

SELinux a orchestrační nástroje (Puppet)

Základní konfigurace

nastavení booleanu

```
selinux::boolean {  
  'nagios_run_sudo':  
    ensure => 'on', }  

```

Nastavení file kontextu

```
selinux::fcontext { 'nagios-check-results-dir-pph':  
  ensure   => 'present',  
  seltype  => 'nagios_tmp_t',  
  pathspec => '/data_local/tmp/check_results(/.*)?', }  

```

```
selinux::exec_restorecon { '/data_local/tmp/check_results':  
  refreshonly => true,  
  subscribe   => Selinux::Fcontext['nagios-check-results-  
dir-pph'], }  

```

Monitoring

- na všech serverech najednou `tail -f /var/log/audit/audit.log | grep avc ?`
- Integrace s nagiosem
- Magická funkce `sealert` toolu
- Smazání duplicitních logů
- `AVC` already allowed in current policy



SELINUX CONFIGURATION FILES

Děkuji za pozornost

MEETUP

Osnova meetupu

1 Anatomie atomického deploye

2 Rollback za pár sekund a CI/CD pipeline v praxi

3 Častější a klidnější deploye



Od deploye přes FTP k anatomickému deployi

Anatomie atomického deploye – jak symlinky eliminují „polonasazenou“ aplikaci a proč je ne-atomický deploy recept na katastrofu

Rollback za pár sekund & CI/CD pipeline v praxi – rychlý návrat k předchozí verzi jedním kliknutím, včetně integrace s GitLab CI

Častější a klidnější deploye – jak historie posledních releases, oddělený build od deploye dávají vývojářům jistotu nasazovat klidně několikrát denně místo jednou za měsíc



26. 05. 2026



18:00



MÍSTO

Osteria Garage
Salonek v 1. patře
Částkova 56, Plzeň

Martin Hora

